

day-06-phase-10-security-scan-safe-hardening

Day 06 Phase 10 â Security Scan Safe Hardening

Objective

Improve security posture with safe app-level hardening only; document host/admin runbook items explicitly.

Result

PARTIAL.

Actions Executed

1. Attempted authenticated scan:
 - 'GET /api/security-scan'
2. Captured current access blocker.
3. Applied safe app-level persistence hardening that supports audited Bridge workflow correctness:
 - '053_bridge_approval_audit_persistence' migration.

Evidence

- 'GET /api/security-scan' returned '401 Unauthorized' in current runtime auth context.
- No fake score increase claimed in this phase.

Blockers

- 'authenticated_local_smoke_blocked'
- owner/session-auth dependency for protected security-scan route

Safe Hardening Applied

- Added Bridge approval/audit table persistence migration and indexes to prevent missing-audit-state runtime drift.
- No auth weakening.
- No '.env' change.
- No destructive host modifications.

Host/Admin Runbook (Still Required)

Pending authenticated or host-level checks for:

- 'hsts_enabled'
- 'firewall'
- 'open_ports'
- 'disk_encryption'
- 'linux_core_dumps'
- 'linux_mac_framework'
- 'linux_tmp_noexec'

Files Changed

- 'src/lib/migrations.ts'
- 'runtime/day-06-phase-10-security-scan-safe-hardening.md'
- 'runtime/day-06-phase-10-security-scan-safe-hardening.pdf'

Tests

- 'pnpm run typecheck' -> PASS
- targeted bridge/session test set -> PASS

Updated Percentage

- Security remains PARTIAL pending authenticated scan score before/after and host-admin action completion.

Exact Next Step

Run authenticated '/api/security-scan', capture baseline score, apply remaining safe app-level fixes, rerun score, and publish exact host-admin checklist deltas.